

LAB 02

NovaPay - Third Party Risk Management

Zorluk: Başlangıç / Orta • Tahmini süre: 30-60 dakika • Rolünüz: GRC Specialist

1. HİKÂYE

Sektör Fintech / ödeme hizmetleri	Ölçek 420 çalışan, 1,8 milyon kullanıcı
BT ortamı AWS, Kubernetes, SaaS müşteri destek platformu	Tedarikçi CloudAssist Ltd. - kritik müşteri destek SaaS'ı

NovaPay, büyüyen müşteri operasyonlarını CloudAssist adlı SaaS sağlayıcısına taşımayı planlamaktadır. Platform müşteri adı, iletişim bilgileri, işlem referansları ve destek yazışmalarını işleyecektir. Satın Alma, kampanya takvimine yetişmek için sözleşmenin iki hafta içinde imzalanmasını istemektedir. Bilgi Güvenliği ön değerlendirmeyi tamamladığını, Hukuk ise veri lokasyonu ve alt yükleniciler konusunda ek açıklama gerektiğini belirtmiştir. Yönetim sizden risk kabul toplantısı öncesi bağımsız bir görüş istemektedir.

2. SİZE VERİLEN GÖREV

Mevcut durum tespiti dosyasını inceleyin, karar için eksik bilgileri belirleyin ve yönetime dengeli bir tedarikçi risk değerlendirmesi sunun. Otomatik olarak 'çalışılsın/çalışılmasın' kararı vermeyin.

3. OLAYLAR VE KANITLAR

E-01 | Tedarikçi anketi
CloudAssist 186 sorunun 171'ini yanıtlamıştır. Şifreleme, erişim ve olay yönetimi yanıtları olumludur. On beş soru 'ticari sır' gerekçesiyle boş bırakılmıştır; bunların altısı BCP ve alt yüklenici yönetimiyle ilgilidir.

E-02 | Sertifikalar
ISO/IEC 27001 sertifikası 30.11.2026'ya kadar geçerlidir; kapsam 'Avrupa müşteri hizmetleri platformu ve destek operasyonları'dır. Sertifikasyon kuruluşu doğrulanmıştır. SoA ve son gözetim raporu paylaşılmamıştır.

E-03 | SOC 2 Type II özeti
Rapor dönemi 01.01-30.09.2025'tir. Bir istisna: ayrıcalıklı erişimlerin %4'ünde üç aylık review gecikmiştir. Yönetim düzeltmenin tamamlandığını beyan eder; bağımsız yeniden test kanıtı yoktur.

E-04 | Veri lokasyonu
Ana veri Frankfurt'ta tutulacaktır. Destek kayıtlarının yedekleri Dublin'dedir. Gece destek hizmeti Filipinler'deki alt yüklenici tarafından sağlanır; sözleşme ekinde bu şirketin adı bulunmaz.

LAB 02

NovaPay - Third Party Risk Management

Zorluk: Başlangıç / Orta • Tahmini süre: 30-60 dakika • Rolünüz: GRC Specialist

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Sözleşme taslağı

Olay bildirimi 'makul süre içinde'; hizmet seviyesi aylık %99,5; veri iadesi 60 gün içinde. Denetim hakkı yılda bir anketle sınırlıdır. Dolaylı zarar sorumluluğu üç aylık ücretle sınırlandırılmıştır.

E-06 | BCP açıklaması

CloudAssist yıllık felaket kurtarma testi yaptığını ve RTO 8 saat/RPO 4 saat hedeflediğini belirtir. NovaPay iş birimi kesinti toleransını 2 saat olarak bildirmiştir.

E-07 | İş birimi e-postası

'Sağlayıcı piyasadaki en iyi firmalardan. Risk ekibinin bütün belgeleri beklemesi lansmanı kaçırmamıza neden olacak. Gerekirse kalan maddeleri canlıya geçtikten sonra kapatabiliriz.'

4. ÖĞRENCİNİN GÖREVLERİ

1. Tedarikçiyi kritik yapan veri, hizmet ve bağımlılıkları belirleyin.
2. Mevcut belgelerin kapsam ve güncelliğini değerlendirin.
3. Sözleşmede müzakere edilmesi gereken maddeleri önceliklendirin.
4. RTO/RPO farkının iş kararına etkisini açıklayın.
5. Alt yüklenici ve veri lokasyonu için hangi ek kanıtları istersiniz?
6. Koşullu onay, risk kabulü veya erteleme seçeneklerini gerekçeleriyle karşılaştırın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Tedarikçi risk özeti ve risk seviyesi
- 5 maddelik eksik kanıt listesi
- 4 sözleşme iyileştirmesi
- Karar seçenekleri ve koşulları
- Yönetime 3-5 cümlelik öneri

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası